

ITSX25 Kurs 6 – Individuell inlämningsuppgift

Workshop 2 – MITRE ATT&CK och hotanalys

Del 1 – Förstå MITRE ATT&CK som analysramverk

Uppgift 1

MITRE ATT&CK används av säkerhetsteam för att förstå, strukturera och beskriva hur angripare kan agera mot system och nätverk. Ramverket ger ett gemensamt språk som gör det lättare för olika personer inom säkerhet att prata om samma typer av hot och beteenden.

ATT&CK kan användas vid hotanalys genom att koppla observerade beteenden till olika tactics och techniques. Därefter kan säkerhetsteamet undersöka hur beteendena skulle kunna upptäckas och vilka säkerhetskontroller som kan minska risken.

En viktig användning är också att identifiera luckor i försvaret. Om en relevant teknik finns i hotbilden men organisationen saknar bra loggning eller detektion kan det bli ett förbättringsområde.

ATT&CK hjälper även till med spårbarhet. Vi kan dokumentera vilken teknik vi har identifierat, vilken källa vi har använt och varför vi tycker att observationen passar in på tekniken.

ATT&CK är därför framför allt ett analys- och försvarsverktyg. Det ersätter inte en egen riskanalys, men ger en strukturerad metod för att förstå hot, kommunicera om dem och prioritera säkerhetsåtgärder.

Uppgift 2

ATT&CK ska inte användas som en checklista för att genomföra attacker eftersom ramverket främst är till för analys och försvar. Det beskriver olika typer av angriparbeteenden, men syftet i en säkerhetsanalys är att förstå dessa beteenden och fundera på hur de kan upptäckas, förhindras och följas upp.

Det finns en viktig skillnad mellan ett analysramverk och en angreppsinstruktion. Ett analysramverk hjälper oss att svara på frågor som varför ett beteende används, vilken risk det innebär och hur vi kan skydda oss. En angreppsinstruktion skulle i stället fokusera på exakta steg för att genomföra ett angrepp.

Om ATT&CK används som en checklista finns dessutom en risk att analysen blir för mekanisk. Bara för att en teknik finns i ATT&CK betyder det inte att den automatiskt är

relevant för vårt projekt. Vi måste ta hänsyn till vår miljö, våra system, vår hotbild och våra säkerhetskontroller.

Vi använder därför ATT&CK för att förstå hotbilden och förbättra försvaret, inte för att lära oss hur man genomför angrepp.

Uppgift 3

- **Initial Access** – beskriver hur en angripare försöker få sin första åtkomst till en miljö eller ett system.
- **Execution** – beskriver hur en angripare försöker få aktivitet eller kod att köras i miljön.
- **Persistence** – beskriver hur en angripare försöker behålla åtkomst till en miljö över tid.
- **Discovery** – beskriver hur en angripare försöker samla information om miljön, exempelvis system, konton och resurser.
- **Impact** – beskriver aktiviteter som kan påverka system, data eller verksamhetens normala funktion.

Tactics beskriver alltså framför allt angriparens övergripande mål, medan techniques beskriver olika sätt att uppnå dessa mål.

Uppgift 4

ATT&CK kan fungera som ett gemensamt språk mellan red team, blue team och ledningen. Red team kan använda ATT&CK för att beskriva vilka typer av angriparbeteenden som är relevanta. Blue team kan använda samma begrepp för att analysera vilka beteenden som kan upptäckas och vilka försvar som finns.

Det gör kommunikationen tydligare eftersom alla team kan använda samma definitioner av tactics och techniques. I stället för att bara säga att något är "misstänkt" kan teamet beskriva vilket beteende som observerats och vilken ATT&CK-teknik det kan kopplas till.

ATT&CK kan också förbättra spårbarheten. Vi kan dokumentera observationen, vår TTP-mappning, vilken källa som använts och hur säkra vi är på vår bedömning.

För ledningen kan informationen sedan översättas till risk och prioritering. Om vi upptäcker att en relevant teknik saknar bra detektion kan det exempelvis bli ett backlog-item.

På så sätt kan ATT&CK koppla samman teknisk säkerhetsanalys med projektstyrning. Red team bidrar med angriparperspektivet, blue team med försvar och upptäckt och ledningen med prioritering utifrån risk och verksamhetsnytta.

Del 2 – TTP: Tactic, Technique och Procedure

Uppgift 5

Tactic beskriver varför angriparen gör något och vilket övergripande mål som eftersträvas.

Technique beskriver hur angriparen försöker uppnå detta mål.

Procedure beskriver hur en viss teknik har använts eller observerats i ett specifikt sammanhang.

Ett exempel är:

Tactic: Discovery

Technique: Account Discovery

Procedure: En angripare försöker identifiera vilka konton som finns i en miljö.

Ur ett defensivt perspektiv kan vi då undersöka om ovanlig kartläggning av konton kan upptäckas genom relevanta loggar och säkerhetskontroller.

Uppgift 6

Teknik 1: Account Discovery

Tactic: Discovery

Technique: Account Discovery

Procedure: Angriparen försöker identifiera konton eller användare i miljön. Ur ett försvarsperspektiv är det relevant att kunna upptäcka ovanlig aktivitet som innebär kartläggning av kontoinformation.

Teknik 2: System Information Discovery

Tactic: Discovery

Technique: System Information Discovery

Procedure: Angriparen försöker samla information om system och deras egenskaper för att förstå miljön. Defensivt kan ovanlig kartläggning av system vara relevant att övervaka.

Teknik 3: Command and Scripting Interpreter

Tactic: Execution

Technique: Command and Scripting Interpreter

Procedure: Angriparen använder ett kommando- eller skriptbaserat gränssnitt för att genomföra aktivitet i miljön. Försvaret behöver kunna skilja normal administrativ aktivitet från avvikande aktivitet.

Uppgift 7

Jag väljer **Discovery**.

Tre tekniker som hör hemma inom denna tactic är:

- Account Discovery
- System Information Discovery
- Network Service Scanning

De passar eftersom de alla handlar om att samla information om en miljö. Angriparen kan försöka förstå vilka användare, system och tjänster som finns.

Ur ett defensivt perspektiv är teknikerna relevanta eftersom ovanlig eller omfattande kartläggning kan vara en signal på att någon försöker förstå miljön.

Uppgift 8

Det kan vara svårt att mappa en observation till rätt teknik eftersom samma aktivitet kan ha flera möjliga förklaringar. En aktivitet kan exempelvis vara legitim för en administratör men misstänkt om den utförs av ett ovanligt konto eller vid en ovanlig tidpunkt.

Kontexten är därför viktig. Vi behöver veta vem som utförde aktiviteten, vilket system som berördes, när den skedde och vad som hände före och efteråt.

Datakvaliteten påverkar också analysen. Om relevanta loggar saknas kan det vara svårt att avgöra vilken technique som passar bäst.

Därför behöver vi använda tillförlitliga källor och dokumentera varför vi gjort en viss mappning. Om vi är osäkra ska vi dokumentera osäkerheten i stället för att presentera vår tolkning som ett faktum.

Del 3 – Bygg en defensiv attackkedja

Uppgift 9

En enkel defensiv attackkedja kan beskrivas som:

Initial Access → **Execution** → **Discovery** → **Credential Access** → **Impact**

Kedjan visar på en övergripande nivå hur ett angrepp kan utvecklas från första åtkomst till möjlig påverkan på verksamheten.

Uppgift 10

Steg	Varför?	Hur?	Vad såg vi?
------	---------	------	-------------

Initial Access	Angriparen behöver få första åtkomst.	Genom ett initial-access-be teende.	En ovanlig eller misstänkt första åtkomst.
Execution	Angriparen behöver kunna genomföra aktivitet.	Genom en execution-technique.	Oväntad aktivitet som körs i miljön.
Discovery	Angriparen behöver förstå miljön.	Genom discovery-beteendet.	Ovanlig kartläggning av konton, system eller nätverk.
Credential Access	Angriparen försöker komma åt autentiseringsrelaterad information.	Genom en credential-access-technique.	Avvikande aktivitet kopplad till autentiseringsinformation.
Impact	Angriparen försöker påverka verksamheten.	Genom en impact-relaterad technique.	Förändringar som påverkar system, data eller tillgänglighet.

Mappningen måste kontrolleras mot de faktiska observationerna och ska inte enbart baseras på vad vi förväntar oss att attackkedjan ska innehålla.

Uppgift 11

Det steg som vi bedömer som mest osäkert är **Credential Access**. Anledningen är att aktiviteter som berör autentiseringsinformation kan ha både legitima och misstänkta förklaringar.

För att förbättra analysen behöver vi veta vilket konto som utförde aktiviteten, vilket system som berördes, när aktiviteten inträffade och om den var förväntad.

Vi behöver även kontrollera vilka loggar som stödjer observationen och om det finns andra händelser som stärker vår TTP-mappning.

Om vi inte kan få fram tillräckligt med information ska vi behålla osäkerheten dokumenterad i stället för att göra ett säkert påstående.

Uppgift 12

Första kontakt



Initial Access



Execution



Discovery



Credential Access



Impact



Påverkan på verksamheten

Del 4 – Försvarsfrågor och Blue/Purple-perspektiv

Uppgift 13

Initial Access:

Hur kan vi upptäcka ovanliga eller misstänkta första åtkomster?

Execution:

Vilka signaler kan visa att aktivitet körs på ett oväntat sätt?

Discovery:

Kan vi upptäcka ovanlig kartläggning av konton, system eller nätverk?

Credential Access:

Hur kan vi upptäcka misstänkt aktivitet kopplad till autentiseringsinformation?

Impact:

Hur kan vi upptäcka förändringar som påverkar systemens tillgänglighet, data eller normala funktion?

Uppgift 14

Account Discovery

Möjliga detektionssignaler är ovanligt omfattande kartläggning av konton, aktivitet från ett konto som normalt inte utför denna typ av aktivitet eller flera discovery-relaterade händelser under en kort period.

Command and Scripting Interpreter

Möjliga signaler är ovanlig användning av kommando- eller skriptmiljöer, aktivitet från användare som normalt inte använder dessa funktioner eller en kombination av execution- och discovery-relaterade händelser.

Signalerna måste jämföras med normal aktivitet eftersom legitima administratörer också kan utföra sådana aktiviteter.

Uppgift 15

Account Discovery

Möjliga riskreducerande åtgärder är att använda principen om minsta privilegium, begränsa onödiga administrativa rättigheter, logga relevanta aktiviteter och regelbundet se över konton och behörigheter.

Command and Scripting Interpreters

Möjliga åtgärder är att begränsa administrativa rättigheter, använda endpoint-skydd, ha relevant loggning och övervaka avvikande användning. Det är också viktigt att ha tydliga rutiner för administrativ aktivitet.

Åtgärderna bör prioriteras utifrån hur stor risk tekniken innebär för vår specifika miljö.

Uppgift 16

En attackkedja hjälper säkerhetsteamet att se ett angrepp som en sammanhängande process i stället för som enskilda händelser. Det gör det lättare att förstå hur olika beteenden kan hänga ihop och var vi kan upptäcka eller stoppa aktiviteten.

Vi kan exempelvis använda kedjan för att identifiera vilka steg vi har bra synlighet för och vilka steg där vi saknar loggar eller detektioner. Om vi kan upptäcka Initial Access men inte Discovery har vi identifierat en möjlig lucka i vårt försvar.

Attackkedjan kan också hjälpa oss att prioritera. Vi behöver inte lösa alla säkerhetsproblem samtidigt utan kan fokusera på de steg som innebär störst risk eller där våra kontroller är svagast.

Efter att en åtgärd har genomförts kan vi följa upp om den faktiskt förbättrade försvaret. Det kan exempelvis innebära att kontrollera om nya loggar eller detektioner ger bättre synlighet.

På så sätt kan attackkedjan kopplas till backlog och sprintarbete. Analysen blir en del av vårt kontinuerliga förbättringsarbete och inte bara en rapport.

Del 5 – Källor, spårbarhet och kvalitet

Uppgift 17

1. **MITRE ATT&CK**

Används som huvudkälla för tactics, techniques och procedures.

2. **MITRE Enterprise Matrix**

Används för att kontrollera strukturen över Enterprise ATT&CK och relationen mellan tactics och techniques.

3. **CISA – Best Practices for MITRE ATT&CK Mapping**

Används för att kontrollera att våra ATT&CK-mappningar har tillräcklig kontext och är rimliga.

4. **MITRE ATT&CK Data & Tools**

Används som kompletterande källa för ATT&CK-data och verktyg.

Uppgift 18

Vi säkerställer att vår TTP-mappning är rimlig genom att jämföra våra observationer med MITRE ATT&CK:s officiella beskrivningar.

För varje mappning dokumenterar vi vad vi observerat, vilken tactic och technique vi valt och varför den passar. Vi dokumenterar också vilken källa som stödjer vår bedömning.

Om det finns alternativa tolkningar ska vi ta upp dem. Om information saknas dokumenterar vi detta som en osäkerhet.

Vi låter även en annan gruppmedlem granska mappningen. På så sätt kan vi upptäcka feltolkningar och säkerställa att slutsatsen inte bara bygger på en persons uppfattning.

Uppgift 19

Definition of Done för hotanalysen:

- Tactic och technique är identifierade.
- Varje TTP-mappning har en motivering.
- Källorna är dokumenterade.
- Osäkerheter är dokumenterade.
- Attackkedjan är logisk och begriplig.
- Försvarsfrågor finns för relevanta steg.
- Analysen har granskats av en annan gruppmedlem.
- Backloggen är uppdaterad.
- Sprint Goal har följts upp.
- Dokumentationen finns i GitHub.
- Gruppen kan förklara analysen med egna ord.

Uppgift 20

En hotanalys blir användbar för andra när den är tydlig, spårbar och möjlig att följa upp. En person som inte varit med under analysen ska kunna förstå vad som har undersökts, vilka slutsatser som dragits och varför.

Det är därför viktigt att använda ett gemensamt språk, exempelvis MITRE ATT&CK:s tactics och techniques. Varje mappning bör också ha en motivering och en källa så att någon annan kan kontrollera resonemanget.

Det är viktigt att skilja mellan fakta och antaganden. Om vi saknar information ska detta dokumenteras som en osäkerhet.

Analysen ska dessutom leda till något konkret. Om vi identifierar en detektionslucka kan den exempelvis bli ett backlog-item.

På så sätt kan analysen användas av andra gruppmedlemmar, lärare eller framtida projektmedlemmar utan att de behöver fråga personen som skrev den vad olika delar betyder.

Del 6 – Koppling till backlog, sprint och Workshop 3

Uppgift 21

Efter Workshop 2 har vi identifierat följande nya eller ändrade backlog-items:

1. **Dokumentera relevanta ATT&CK-tekniker**
Vi behöver dokumentera vilka tactics och techniques som är relevanta för vår hotanalys.
2. **Identifiera detektionsmöjligheter**
Vi behöver undersöka vilka typer av signaler som kan användas för att upptäcka relevanta beteenden.
3. **Dokumentera säkerhetsluckor**
Vi behöver dokumentera de delar av attackkedjan där vi har begränsad synlighet eller osäkerhet.
4. **Uppdatera Definition of Done**
Vi behöver säkerställa att TTP-mappning, källor och osäkerheter ingår i våra kriterier för färdigt arbete.
5. **Förbereda Workshop 3**
Vi behöver samla öppna frågor och bestämma vilka delar av analysen som ska följas upp.

Dessa items bör även dokumenteras i vår GitHub-backlog så att det finns spårbarhet mellan hotanalysen och vårt fortsatta projektarbete.

Uppgift 22

Attackkedjan är relevant för vårt Sprint Goal eftersom den hjälper oss att förstå vilka säkerhetsrisker och beteenden som är relevanta för projektet.

Efter Workshop 2 bedömer vi att Sprint Goal fortfarande är relevant. Däremot har analysen visat att vissa delar behöver undersökas mer, framför allt de delar där TTP-mappningen är osäker eller där vi saknar tillräcklig information.

Om vi identifierar en säkerhetsrisk som är viktigare än ett befintligt backlog-item behöver vi diskutera om prioriteringen ska ändras.

Attackkedjan fungerar därför som ett underlag för att kontrollera att vårt sprintarbete fortfarande fokuserar på rätt risker och projektmål.

Uppgift 23

- Är våra ATT&CK-mappningar rimliga utifrån de observationer och källor vi har?
- Vilka delar av attackkedjan behöver vi undersöka mer för att minska vår osäkerhet?
- Vilka säkerhetsluckor bör vi prioritera i nästa sprint?
- Är vår Definition of Done tillräcklig för att säkerställa att hotanalysen är färdig och spårbar?

Uppgift 24

Vi har analyserat MITRE ATT&CK och använt tactics och techniques för att strukturera vår hotanalys.

Vi har skapat en defensiv attackkedja från Initial Access till Impact.

Vi har identifierat möjliga detektionssignaler och riskreducerande åtgärder.

Vi har dokumenterat våra källor och hur vi har gjort vår TTP-mappning.

Vi har identifierat delar av analysen som fortfarande är osäkra.

Vi har kopplat analysen till vår backlog, Definition of Done och Sprint Goal.

Inför Workshop 3 vill vi verifiera våra osäkerheter, prioritera nästa steg och säkerställa att alla i gruppen kan förklara analysen med egna ord.

Projektspårbarhet

- Har vi uppdaterat vår backlog?
- Har vi följt upp vårt Sprint Goal?
- Har vi använt vår Definition of Done?
- Har vi dokumenterat vad vi är osäkra på?

Teamförberedelse

- Kan alla i gruppen förklara analysen med egna ord?
- Vet gruppen vad som är klart och vad som återstår?
- Har gruppen minst två frågor till Workshop 3?
- Har gruppen identifierat nästa steg?

Inför retrospektiv

Vad gick bra?

Vi fick en bättre förståelse för MITRE ATT&CK och kunde koppla TTP till hotanalys och försvar.

Vad blev svårt?

Det var framför allt svårt att avgöra exakt vilken technique vissa observationer skulle kopplas till.

Vad behöver vi ändra?

Vi behöver dokumentera osäkerheter tidigare och kontrollera våra mappningar mot tillförlitliga källor.

Vad tar vi med oss till nästa sprint?

Vi tar med oss en tydligare process för TTP-mappning, källkontroll, dokumentation och prioritering.

AI-användning

Jag använde en generativ AI-assistent som stöd för att strukturera och formulera delar av hotanalysen samt för att få hjälp med MITRE ATT&CK-begrepp. Informationen kontrollerades manuellt mot MITRE ATT&CK:s officiella dokumentation och CISA:s material. Jag kontrollerade även TTP-mappningarna och anpassade innehållet efter vårt eget projekt.

AI användes därför som ett stöd i arbetet och inte som ensam källa.